Poorav Saini

Application Security Engineer | Web & API Security Researcher

Location: Delhi NCR, India · Open to relocate

Email: puneetsaini1999@gmail.com | **Phone**: +91 80583 36563

LinkedIn: linkedin.com/in/poorav-saini-056849277 **| GitHub:** github.com/RooterKali

Portfolio: rooterkali.github.io/RooterKali/portfolio/

SUMMARY

Security researcher with 4 years of independent vulnerability research across web applications, APIs, and OAuth/SSO authentication flows. Submitted 30+ reports to HackerOne and Intigriti programs covering broken authentication, access control, dependency confusion, and information disclosure, with one finding triaged as actionable by a program team. Additional self-assessed High and Critical findings on self-hosted and CTF-style deployments, including an SSO authentication bypass exposing an internal admin dashboard. Regular CTF participant on HackingHub and Pwnbox. Builds custom research tooling and AI-agent systems for autonomous reconnaissance. Certified AppSec Practitioner (CAP).

TECHNICAL SKILLS

Web & API Security: OWASP Web Top 10, OWASP API Top 10 (2023), broken authentication, session fixation, IDOR, access control, race conditions (TOCTOU), business logic flaws, information disclosure, open redirect, CSRF, XSS, SSRF, buffer overflow, A/C takeovers, SQL Injection, JWT cracking

Authentication & Identity: OAuth 2.0, OIDC, SSO, SAML, session management, authorization bypass, account takeover

Supply Chain Security: Dependency confusion, package namespace analysis, source-map leakage, exposed dependency triage

Recon & Enumeration: Amass, subfinder, assetfinder, crtsh, gau, waybackurls, waymore, katana, ffuf, Feroxbuster, Arjun, dirsearch, Google dorking, GitHub dorking, URL scraping, JavaScript endpoint extraction, parameter discovery, directory brute forcing

Tooling: Burp Suite Advanced (manual hunting, active scanning, Intruder, param-miner, gap, custom jsanalyzer), Caido, Python, Linux, nuclei, Nmap, sqlmap, n8n, Model Context Protocol (MCP), custom scripts

Methodology: Vulnerability discovery, manual security analysis, PoC development, exploitation validation, retest and remediation verification, attack surface mapping

AI & Automation: AI agent architecture, Model Context Protocol (MCP), agent skill authoring, autonomous reconnaissance pipelines, LLM-assisted vulnerability triage and reporting

Reporting: Vulnerability writeups, severity assessment, reproducible PoC documentation, disclosure timelines

PROFESSIONAL EXPERIENCE

Independent Security Researcher — Bug Bounty | 2022 – Present | *HackerOne · Intigriti · Self-hosted*

- **Broken Authentication, SSO & Account Takeover:** Tested OAuth 2.0 and SSO flows across multiple programs, finding authentication bypass, session fixation, and open-redirect flaws that leaked authorization codes and enabled full account takeover. Findings self-assessed High.
- **Access Control:** Discovered unauthenticated internal admin dashboards and weak authorization paths, demonstrating unauthorized privileged access to application assets.
- **Supply Chain:** Reported dependency confusion across package ecosystems, including one case still open with the target program; led to development of the MapGhost scanner.
- **Information Disclosure:** Reported leaked API keys and a critical authentication bypass exposing all users' support tickets in bulk without any login, allowing any requester to read another user's ticket history. Used manual and tool-assisted GitHub dorking to locate exposed keys.
- **Reporting Volume:** Reported vulnerabilities across HackerOne, Intigriti, and self-hosted programs, including dependency confusion findings reported on both HackerOne and self-hosted targets.
- **CTF Practice:** Solve web exploitation, reconnaissance, API security, and reverse engineering challenges in live CTF environments under time constraints; see CTF & Practice Platforms for public profiles.
- **Custom Tooling:** Developed Python automation for asset discovery, dependency reference parsing, and package-availability verification.

AI-AGENT SECURITY RESEARCH

- **Agent Architecture:** Architected autonomous security research agents that decompose targets, plan test paths, and execute reconnaissance across web assets, repositories, and exposed sources.
- **MCP Integrations:** Connected Burp Suite and external tool servers to AI agents over Model Context Protocol (MCP), enabling agents to invoke security tooling, collect responses, and reason over results programmatically.
- **OAuth Research Agent:** Engineered a dedicated agent for OAuth 2.0 and OIDC flow analysis that enumerates authorization endpoints, maps redirect URI handling, and tests authorization code and token exchange paths.
- **Human-in-the-Loop Validation:** Every agent-generated finding was manually verified through Burp Suite and exploit reproduction; agent output reduced triage time and expanded reconnaissance coverage rather than replacing analyst judgment.
- **Skill Libraries:** Authored reusable agent skill files encoding repeatable research procedures so agents execute consistent methodology across targets.
- **Automated Discovery:** Orchestrated n8n and MCP pipelines automating asset enumeration, dependency reference extraction, package availability checks, and finding triage.

PROJECTS

- **MapGhost:** github.com/RooterKali/RooterKali/blob/main/mapghost/README.md — Source-map-based dependency-confusion scanner that crawls targets for exposed .map files, extracts package references with a Node AST parser, and scores findings across 4 severity tiers with JSON and HTML reporting. Supports 7 operating modes, including single-domain, bulk-list, sourcemap-batch, and scheduled scanning, with resume state and Discord webhook alerting. Private implementation; public use-case documentation linked.
- **npm-package-validation:** github.com/RooterKali/npm-package-validation — Public source-map triage utility that identifies exposed dependency references and accelerates vulnerability exposure analysis.
- **For Hackers From Hackers:** github.com/RooterKali/For-Hackers-From-Hackers — Ongoing publication of vulnerability writeups and exploitation analysis for the security research community.
- **n8n Automation Workflows:** Configure and extend community n8n workflows for HackerOne scope monitoring, CVE summarization, bug bounty tip harvesting, nuclei template generation, and report summarization to support own-target research.

CTF & PRACTICE PLATFORMS

Regular participant on live attack/defense CTF environments. Public profiles: HackingHub | Pwnbox

Solve web exploitation, reconnaissance, API security, and reverse engineering challenges under time constraints, applying the same manual methodology used on bounty targets.

CERTIFICATIONS

Certified AppSec Practitioner (CAP) — The SecOps Group | Issued 30-Jul-2026 | Exam v1.01 | Credential ID 11712748

Practical Ethical Hacking — TCM Security

Ethical Hacking Essentials — EC-Council

EDUCATION

Bachelor of Commerce (B.Com) | 2021
Raj Rishi Bharthari Matsya University, Alwar